CORELINK — PLANO DE INCREMENTO FUNCIONAL • NATIVIDADE-TO

VULNERABILIDADE 3: RISCO DE BYPASSING ADMINISTRATIVO (RBAC)

HJ Infor — Verificação Estrita de Papéis no Middleware (src/proxy.ts) e Revalidação PostgreSQL em /admin/pedidos/export

MÓDULO DE SEGURANÇA	CATEGORIA OWASP	STACK	DATA DE EXECUÇÃO
Middleware & Exportação CSV	A01:2021 — Broken Access Control	Next.js 16 Proxy, NextAuth v5	25/10/2026

1. VULNERABILIDADE SELECIONADA E PRIORIZAÇÃO

VULNERABILIDADE MITIGADA

Vulnerabilidade 3 (Risco de Bypassing Administrativo): Falta de verificação estrita de papéis no middleware permitia tentativas de requisição não autorizada à rota de exportação CSV (`/admin/pedidos/export`).

Justificativa Técnica: Na arquitetura do Next.js App Router, o arquivo `src/app/admin/layout.tsx` protege apenas componentes de página (`page.tsx`), não sendo executado para *Route Handlers* como `/admin/pedidos/export/route.ts`. Sem um Middleware/Proxy global (`src/proxy.ts`) na borda da aplicação e sem revalidação do papel (`role === "ADMIN"`) diretamente no PostgreSQL, tentativas de acesso direto por usuários autenticados com perfil `CUSTOMER` ou portadores de tokens JWT antigos/revogados não eram barradas no perímetro de rede.

2. RESULTADO ESPERADO E COMPORTAMENTO ALCANÇADO

RBAC DUPLA CAMADA ATIVO

Foi implementada uma defesa de **Controle de Acesso Baseado em Papéis (RBAC) em 2 camadas**: (1) **Middleware Global na Borda (`src/proxy.ts` + `src/lib/rbac-middleware.ts`)** interceptando `/admin/:path*` antes do roteamento, retornando `401 Unauthorized` para requisições anônimas e `403 Forbidden` (`RBAC_FORBIDDEN_403`) para clientes comuns tentando acessar `/admin/pedidos/export` ; e (2) **Revalidação no Banco PostgreSQL (`route.ts`)** confirmando se o usuário mantém `role === "ADMIN"` ativa no banco antes de gerar o CSV, além de sanitização contra *CSV Formula Injection*.

3. PLANO DE EXECUÇÃO DETALHADO

ATIVIDADE	RESPONSÁVEL	TECNOLOGIAS	PERÍODO	STATUS
Separação da Configuração Edge (`src/auth.config.ts`). Isolamento dos callbacks JWT/Session do NextAuth v5 para execução leve no Middleware.	Marques Ramirez	NextAuth v5 (Auth.js), TypeScript, JWT Strategy	22/10 a 23/10/2026	✓ Concluída
Implementação do Middleware RBAC (`src/proxy.ts` e `rbac-middleware.ts`). Interceptação estrita de `/admin/:path*` e `/admin/pedidos/export`.	Márcio Medrado	Next.js 16 Proxy, `NextResponse`, HTTP 401/403	23/10 a 24/10/2026	✓ Concluída
Revalidação no PostgreSQL e Anti-Formula Injection (`route.ts`). Consulta `prisma.user.findUnique` e blindagem de células CSV (`=, +, -, @`).	Marques Ramirez & Márcio Medrado	Prisma ORM, PostgreSQL, Security Headers	24/10 a 25/10/2026	✓ Concluída
Auditoria de Tentativas de Bypass (`test-rbac-vuln3.mjs`). Testes de penetração com usuário anônimo, cliente `CUSTOMER` e token JWT revogado.	Taís Fernandes, Romildo & Vandelice	Node.js, Simulação de Vetores OWASP A01	25/10/2026	✓ Concluída
Documentação de Segurança e Relatório PDF. Consolidação da arquitetura RBAC e geração do relatório institucional de 2 páginas A4.	Andréa Ribeiro	Git, GitHub, Markdown, PDF Engine	25/10/2026	✓ Concluída

4. ESPECIFICAÇÃO DA ARQUITETURA DE VERIFICAÇÃO ESTRITA DE PAPÉIS (RBAC)

ZERO TRUST ADMIN

ARQUIVO / MÓDULO	ESCOPO DE PROTEÇÃO	REGRA DE CONTROLE DE ACESSO E RESPOSTA DE SEGURANÇA
`src/proxy.ts` & `src/auth.config.ts`	`/admin/:path*` , `/minha-conta/:path*`	Inspeciona o token JWT assinado na borda antes de qualquer página ou Route Handler; injeta `x-rbac-verified: ADMIN` apenas para gestores.
`src/lib/rbac-middleware.ts` (`evaluateAdminRbacMiddleware`)	`/admin/pedidos/export` e Rotas Admin	Retorna JSON `401 Unauthorized` para acesso sem sessão e `403 Forbidden` (`RBAC_FORBIDDEN_403`) para usuários `CUSTOMER` tentando bypass.
`pedidos/export/route.ts` (Revalidação DB)	`GET /admin/pedidos/export`	Executa `prisma.user.findUnique` para confirmar que o papel `ADMIN` não foi revogado no PostgreSQL após a emissão do JWT (`403 RBAC_DB_REVOKED`).
`pedidos/export/route.ts` (`csvCell` + Headers)	Payload CSV Exportado	Neutraliza *CSV Formula Injection* prefixando `=, +, -, @` com apóstrofo e define `Cache-Control: no-store` e `X-Content-Type-Options: nosniff` .

5. EVIDÊNCIA VISUAL: MATRIZ DE CONTENÇÃO RBAC NA ROTA /ADMIN/PEDIDOS/EXPORT

AUDITORIA OWASP A01

ACESSO ANÔNIMO (/EXPORT)	BYPASS CLIENTE (CUSTOMER)	TOKEN JWT REVOGADO NO DB	GESTOR VÁLIDO (ADMIN)
HTTP 401 Bloqueado	HTTP 403 Forbidden	HTTP 403 Revoked	HTTP 200 CSV Seguro

1. Tentativas de Bypassing Interceptadas (Negadas)
Bloqueio imediato na camada de Middleware (src/proxy.ts) e Banco

GET /admin/pedidos/export (Sem Cookie JWT)	401 AUTH_REQUIRED
GET /admin/pedidos/export (Role: CUSTOMER)	403 RBAC_FORBIDDEN
GET /admin/pedidos/export (JWT Admin revogado no DB)	403 DB_REVOKED

2. Fluxo Autorizado e Cabeçalhos de Segurança
Verificação dupla (JWT + PostgreSQL) + Anti-Formula Injection

1ª Camada (src/proxy.ts): token.role === "ADMIN"	✓ x-rbac-verified
2ª Camada (route.ts): dbAdminUser.role === "ADMIN"	✓ ADMIN-DB OK
Download CSV: Cache-Control: no-store | nosniff	✓ 200 OK (UTF-8 BOM)

6. IMPLEMENTAÇÃO TÉCNICA (SRC/PROXY.TS, RBAC-MIDDLEWARE.TS E ROUTE.TS) E LOG DE AUDITORIA

CÓDIGO & TELEMETRIA

6.1 Middleware RBAC (src/lib/rbac-middleware.ts & src/proxy.ts)

```
export function evaluateAdminRbacMiddleware(
  req: NextRequest, user: AuthenticatedSessionUser | null | undefined
): NextResponse | null {
  const { pathname } = req.nextUrl;
  const isExportOrApi = pathname.startsWith("/admin/pedidos/export");

  if (pathname.startsWith("/admin")) {
    if (!user || !user.id) {
      if (isExportOrApi)
        return NextResponse.json(
          { success: false, code: "AUTH_REQUIRED_401" }, { status: 401 }
        );
      return NextResponse.redirect(new URL("/login", req.nextUrl.origin));
    }
    if (user.role !== "ADMIN") {
      if (isExportOrApi)
        return NextResponse.json(
          { success: false, code: "RBAC_FORBIDDEN_403", requiredRole: "ADMIN" },
          { status: 403 }
        );
      return NextResponse.redirect(new URL("/minha-conta?erro=acesso-restrito-admin", req.nextUrl.origin));
    }
  }
  return null;
}
```

6.2 Revalidação no Banco (route.ts) & Log Oficial do Teste

```
// src/app/admin/pedidos/export/route.ts — 2ª Camada no PostgreSQL
const dbAdminUser = await prisma.user.findUnique({
  where: { id: session.user.id },
  select: { id: true, email: true, role: true },
});
if (!dbAdminUser || dbAdminUser.role !== "ADMIN") {
  return NextResponse.json(
    { success: false, code: "RBAC_DB_REVOKED_403" }, { status: 403 }
  );
}

================================================================================
 AUDITORIA DE SEGURANCA - VULNERABILIDADE 3 (RBAC & BYPASS ADMINISTRATIVO)
================================================================================
 [HTTP 401] 1. Requisicao Anonima em /admin/pedidos/export
            → BLOQUEADO (Anonimo sem sessao) [Middleware (src/proxy.ts)]
 [HTTP 403] 2. Cliente Logado (CUSTOMER) tentando Bypass CSV
            → BLOQUEADO (Bypass negado para role=CUSTOMER) [Middleware]
 [HTTP 403] 3. Token JWT Antigo (ADMIN revogado no Banco)
            → BLOQUEADO (JWT revogado no PostgreSQL) [Route Handler]
 [HTTP 200] 4. Gestor Autenticado (ADMIN no JWT e no Banco)
            → PERMITIDO (Exportacao CSV Segura) [Middleware + Handler]
================================================================================
```

7. ROTEIRO DE VALIDAÇÃO E TESTES DE SEGURANÇA (HOMOLOGAÇÃO)

CENÁRIO DE TESTE	PROCEDIMENTO EXECUTADO	RESULTADO OBTIDO NA HOMOLOGAÇÃO
Requisição Direta Sem Autenticação	Disparar `GET /admin/pedidos/export` sem sessão ativa.	Interceptado na 1ª camada (`src/proxy.ts`) com retorno imediato **HTTP 401 Unauthorized** (`AUTH_REQUIRED_401`).
Tentativa de Bypass por Cliente (`CUSTOMER`)	Autenticar como cliente corporativo e requisitar diretamente `/admin/pedidos/export` .	Bloqueado pelo Middleware RBAC com **HTTP 403 Forbidden** (`RBAC_FORBIDDEN_403`) e registro em log de auditoria.
Token JWT com Papel Revogado no Banco	Simular sessão JWT com `role="ADMIN"` cujo registro no PostgreSQL foi rebaixado para `CUSTOMER` .	A 2ª camada em `route.ts` (`prisma.user.findUnique`) barrou a exportação com **HTTP 403** (`RBAC_DB_REVOKED_403`).
Exportação Legítima por Gestor (`ADMIN`)	Clicar no botão *"CSV"* em `/admin/pedidos` logado como administrador.	Retorno **HTTP 200 OK** com arquivo CSV íntegro, células protegidas contra *Formula Injection* e `Cache-Control: no-store` .